Gateproof 보안 점검 보고서

대상

- 프로젝트: `examples/demo-api/`
- 점검 트랙:
  - `gateproof:kisa-check`
  - `gateproof:full-security-check`
- 점검 방식: 현재 저장소 상태를 기준으로 한 session-native 리뷰

요약

`examples/demo-api/`는 현재 상태로는 한국형 감사 대응 관점에서도, 실제 운영 보안 관점에서도 배포 적합성이 낮습니다. KISA 관점에서는 관리자 노출, 비밀정보 관리, 로그인 보호, 로그 위생, 운영 신뢰경계에서 핵심 실패가 확인됐고, 심화 보안 관점에서는 이 중 여러 항목이 실제 공격으로 바로 이어질 수 있는 취약점으로 드러났습니다.

가장 심각한 문제는 인증 없는 관리자 데이터 노출, 사용자 입력 기반 SSRF, 코드에 포함된 자격증명과 약한 JWT 비밀값, 그리고 `pull_request_target` 기반 CI에서 운영 비밀이 노출될 수 있는 흐름입니다. 이 이슈들은 작은 파일 집합 안에서 바로 보이므로, 문서 보강이 아니라 즉시 수정이 필요한 엔지니어링 블로커로 보는 것이 맞습니다.

형식 추천

이번 패키지는 용도가 다른 두 형식을 함께 제공합니다.

- PDF: 공유, 결재, 리뷰, 감사 대응용 최종본에 적합
- Excel: 담당자 지정, 조치 추적, 상태 관리용 실무 포맷에 적합

하나만 선택해야 한다면 PDF가 기본값으로 더 적합합니다. 실행 추적까지 같이 할 거면 Excel 파일을 함께 쓰는 조합이 가장 좋습니다.

핵심 결과

트랙	컨트롤	상태	심각도	핵심 이슈
KISA	`KISA-ACS-01`	Fail	High	공개된 관리자 표면과 인증 없는 관리자 라우트
KISA	`KISA-ENC-02`	Fail	High	코드에 비밀정보와 자격증명 포함
KISA	`KISA-LOG-04`	Fail	High	로그인 요청 본문이 로그에 남을 수 있음
KISA	`KISA-ACC-04`	Fail	Medium	로그인 시도 제한이나 잠금 제어 부재
Full Security	`MOD-APP-01`	Open	Critical	권한검사 없이 관리자 데이터 노출

트랙	컨트롤	상태	심각도	핵심 이슈
Full Security	`MOD-APP-03`	Open	Critical	`/preview?url=` 기반 SSRF
Full Security	`MOD-SUP-02`	Open	Critical	`pull_request_target` 워크플로에서 `PROD_API_KEY` 노출 가능
Full Security	`MOD-DAT-01`	Open	High	약한 JWT 기본값과 평문 자격증명

KISA 관점 평가

KISA 관점에서 보면 이 서비스는 현재 상태로 기본 점검 통과 가능성이 낮습니다. 특히 다음 항목들이 핵심 실패 포인트입니다.

주요 실패 항목

1. `KISA-ACS-01` 관리자 표면 최소화
   - `config/ingress.yaml`에서 `admin.demo.example.com`이 공개 라우팅됨
   - `src/server.js`의 `/admin/users`에 명확한 인증 게이트가 없음
2. `KISA-ENC-02` 소스코드 외부 비밀관리
   - `src/auth.js`에 `JWT_SECRET` 기본 문자열이 존재함
   - 동일 파일에 사용자 비밀번호가 포함되어 있음
3. `KISA-LOG-04` 민감정보 로그 제외 또는 마스킹
   - `src/server.js`에서 로그인 요청 본문을 그대로 기록함
4. `KISA-ACC-04` 로그인 실패 제한 또는 잠금
   - `/login` 주변에 눈에 띄는 throttling, lockout, 프록시 차단 정책이 없음

누락된 증적

- MFA 같은 강화된 관리자 인증
- ingress 수준의 TLS 강제 증적
- 비밀정보 회전 절차
- 로그 보관 주기와 리뷰 책임자
- 의존성 및 패치 위생 증적

Full Security 관점 평가

심화 보안 관점에서는 여러 이슈가 단순 체크리스트 수준이 아니라 실제 공격 경로로 이어집니다.

최고 위험 이슈

1. `MOD-APP-01` 객체 수준 권한검사
   - `GET /admin/users`가 권한검사 없이 전체 사용자 목록을 반환함
2. `MOD-APP-03` SSRF 및 외부 요청 신뢰경계
   - `/preview?url=`가 공격자 입력을 그대로 `fetch(targetUrl)`에 전달함
3. `MOD-SUP-02` CI/CD 신뢰경계
   - 워크플로가 `pull_request_target`에서 실행됨
   - `PROD_API_KEY`가 CI 로그에 출력됨

4. `MOD-DAT-01` 비밀정보 노출 방지
    - 하드코딩된 자격증명과 약한 JWT 기본 비밀값이 존재함

가능한 공격 흐름

1. 외부 사용자가 `/admin/users`를 호출해 전체 사용자 목록을 수집함
2. 공격자가 `/preview?url=`로 내부 서비스나 메타데이터 엔드포인트를 탐색함
3. 신뢰되지 않은 PR이 CI 로그를 통해 운영 비밀을 노출시킴
4. 런타임 비밀값이 설정되지 않으면 알려진 기본 키로 JWT 위조 가능성이 생김

권장 조치 순서

1. 관리자 표면 공개를 제거하고 `/admin/users`에 인증된 관리자 권한검사를 강제합니다.
2. CI에서 운영 비밀이 노출되지 않도록 분리하고, 신뢰된 배포 단계와 신뢰되지 않은 PR 검증 단계를 분리합니다.
3. 코드에 포함된 자격증명을 제거하고, 런타임 비밀 주입을 강제한 뒤 노출된 값을 교체합니다.
4. `/preview`에 대해 allowlist, 사설 대역 차단 등 SSRF 방어를 추가합니다.
5. 로그인 요청 본문 로깅을 중단하고, 시도 제한이나 잠금 같은 남용 방어를 추가합니다.